대외비 2급

외주용역 보안관리 지침서

2012. 02

연세대학교 의료원
YONSEI UNIVERSITY HEALTH SYSTEM

제 개정 이력

제 개정번호	일자	제 개정 내용 요약	작성자
2012-01	2012-02-22	ISO27001 인증 대비 전면 개정	조남인
2013-01	2013-07-17	[별지 제2호 서식] 4. 라. 포맷 → 완전삭제 문구수정	조남인
2016-01	2016-01-29	[별지 제3호 서식] 서식 변경	조남인
2020-01	2020-11-04	제5조(제3자 및 외주용역 계약에 있어서의 보안 필수사항 문구 수정	조남인
2023-01	2024-01-08	제3조(용어의 정의)	조남인

목 차

제1조 (목적) **3**

제2조 (적용범위) **3**

제3조 (용어의 정의) **3**

제4조 (책임과 역할) **3**

제5조 (외주용역 계약에 있어서의 보안 필수사항) **4**

제6조 (외주 용역업체 보안 감사) **5**

제7조 (시행과 갱신) **6**

제1조 (목적)

본 지침서는 연세대학교 의료원 (이하 산하기관 모두 포함하여 '의료원'이라 칭함)의 외주 용역 전반에 대한 적절한 접근 통제와 보안 요구 사항을 계약서 혹은 부속 명세서상에 명확히 명시함으로써 법적 대응조치 수준을 높이며, 외주 용역 계약으로 인해 발생할 수 있는 위협 및 취약성에 대한 위험 수준을 낮추어서 의료원의 정보자산을 외부로부터 적절히 보호하고자 함을 목적으로 한다.

제2조 (적용범위)

의료원에 외주 용역 계약에 의해 서비스 및 인력 등을 공급하는 업체와의 모든 거래행위에 적용한다.

제3조 (용어의 정의)

① 외주용역: 의료원의 이익을 위하여 의료원과 업무 계약이 체결된 업체 또는 개인

제4조 (책임과 역할)

① 최고정보보호책임자 : 의료원의 정보시스템 총괄 책임자로서 의료원 정보보호와 개인정보보호 책임자 역할을 겸직 수행한다.

② 정보보호책임자 : 최고정보보호책임자에 의해 위임된 정보보호 업무를 수행한다.

③ 정보보호관리자 : 각 부서장으로서 부서의 정보보호와 개인정보보호를 직접 수행하며 부서 보안사고에 대한 책임을 진다.

④ 정보보호실무책임자 : 정보보호 주관 부서장으로서 전사적인 정보보호와 개인정보보호 정책 수립 및 이행하며 정보보호관리자(각 부서장)의 정보보호 활동을 지원한다.

⑤ 정보보호 및 보안 실무담당자 : 정보보호실무책임자가 임명한 정보보호 및 개인정보보호 업무 담당자로서 의료원 정보보호 및 개인정보보호를 위한 관리적/물리적/기술적 부문에서 각 부서의 관련 제반 업무를 지원하며 본 지침서의 이행 점검을 수행한다.

⑥ 부서 정보보호담당자 : 정보보호관리자(각 부서장)이 임명한 부서의 정보보호담당자로서 의료원 정보보호 정책이 이행될 수 있도록 부서 내에서 정보보호 업무를 성실히 수행한다.

⑦ 사용자 : 직번 계정(ID)과 도메인 계정(AD)을 부여 받아 정보시스템에서 제공하는 서비스를 이용하여 업무를 처리하거나 정보를 획득하는 자로서 의료원 교직원 뿐 아니라 파견업체나 협력업체 등 외부자를 포함하며, 사용자는 의료원의 정보자산을 보호하고, 정보보호 규정 및 지침서를 성실히 준수해야 할 의무를 갖는다.

제5조 (외주용역 계약에 있어서의 보안 필수사항)

정보시스템, 네트워크 및 데스크탑 환경의 일부 또는 전부에 대한 관리와 통제를 외주 용역하는 경우에는 보안 요구사항에 대하여 당사자간의 합의한 내용이 계약서상에 언급되어야 한다.

① 외주 용역 당사자는 "인적보안지침서 정보보호서약서"를 제출하여야 하며, 정보보호관리자(소속 부서장)은 필요에 따라 별도의 서약서를 징구할 수 있다. 미 제출시 외주 용역의 업무를 박탈할 수 있다.

② 자산관리책임자는 외주 용역 계약자를 포함하여 외주 용역에 관련된 모든 당사자들에게 보안 책임을 주지시켜야 한다.

③ 정보보호실무책임자는 의료원의 중요한 정보에 대한 접근을 제한하여야 하며, 필요 시 최고정보보호책임자의 허가된 자에 한하여 물리적 또는 논리적 접근을 허용한다.

④ 외주 용역 계약업체는 재난이 발생하였을 경우에 서비스의 가용성과 지속성을 유지하기 위한 비상계획을 수립하며 다음의 사항을 포함하여야 한다.

i. 비상계획 및 테스트 결과의 확인

ii. 백업자료의 확보방안 수립

iii. 개발업무에 대한 문서화 유지

iv. 서비스 중단 시 프로그램 및 기기 확보방안 수립

⑤ 업체 도산 및 기타의 이유 등으로 인한 업체 유고 시를 대비하여 상호 협의된 제3의 장소에 소스코드 보관, 핵심인원 승계 및 기타 필요한 이행사항을 정의하여야 한다.

⑥ 외주 용역 사업 계약시 다음과 같은 내용이 계약서에 명기되어야 한다.

i. 계약으로부터 발생되는 권리 또는 의무를 제3자에게 양도하거나 승계할 수 없음을 명기하여야 한다.

ii. 외주 용역 업무 수행 중 정보 유출에 따른 법적 민•형사상의 모든 책임은 당사자와 해당 외주 용역 계약업체에 있다.

iii. 개인정보 업무 목적 외 사용 금지, 개인정보 활용 통제등의 개인정보보호 의무에 대해 명기되어야 한다.

iv. 외주 용역사업 수행 결과물의 소유권과 지적재산권은 의료원에 있다.

v. 기타 외주 용역 업무 계약 시 보안 관련 내용은 “[별지 제2호 서식] 정보화 용역사업 정보보호 준수사항”과 “개인정보 업무 위탁 매뉴얼“를 준용한다.

⑦ 외주 용역사업에 의한 용역개발 및 운용에 대해서는 다음 사항에 대한 통제방안을 수립하여야 한다.

i. 중요 기기설치 장소 및 통제구역에 대한 출입통제

ii. 주요 프로그램 변경에 대한 통제

iii. 의료원 정보자산에 대한 해킹 등 불법 접근방지 대책 수립

iv. 고객정보 보관, 처리용 전산기기 및 통신망의 독립적 사용. 단, 정보보호관리자(소속 부사장)가 필요하다고 인정한 경우, 구체적인 통제방안을 수립한 후 사용

v. 자료 반출입에 대한 통제

vi. 아웃소싱 업체에 의한 개발 시 실제 고객정보 사용불가

제6조 (외주 용역업체 보안 감사)

① 정보보호 담당부서에서는 상기 외주 용역 업체가 확정된 정보보호 규정, 지침 및 절차를 준수하고 있는지를 감사하기 위해서 업체와의 협의 하에 실사하도록 한다.

② 감사의 권한, 범위 및 주기를 설정하여 감사를 실시하도록 하며 다음과 같은 지침을 수행하고 있는지 감사를 실시한다.

i. 외주 용역 계약자를 포함하여 관련된 모든 당사자들에게 보안 책임을

주지시키기 위한 절차를 수행하고 있는지 감사를 실시한다.

ii. 의료원의 중요 자산에 대한 무결성과 기밀성을 유지하며 검사하는 방법을 가지고 있는지 감사한다.

iii. 감사의 권한, 범위 및 주기를 정한다.

iv. 업체 도산 및 기타의 이유 등으로 인한 업체 유고 시를 대비하여 상호 협의된 제3의 장소에 소스코드 보관, 핵심인원 승계 및 기타 필요한 이행사항을 정의하였는지 감사한다.

v. 계약으로부터 발생되는 권리 또는 의무를 외주용역에게 양도하거나 승계할 수 없음을 명기하였는지 감사한다.

제7조 (시행과 갱신)

상기 지침서의 시행과 갱신을 위한 상세한 세부사항은 정보보호규정 '제4장 정보보호 정책'에 준한다.

[별지 제1호 서식] 삭제<2024.01.08>

[별지 제2호 서식] 정보화 용역사업 정보보호 준수사항

정보화사업 용역업체 보안 준수사항

연세대학교 의료원(이하 산하기관을 포함하여 '의료원'이하 칭함) 정보화사업에 참여하는 용역업체는 다음 사항을 참고하여 정보보호 요구사항을 준수하여야 한다.

1.일반사항

가. 의료원의 정보보호 정책, 지침 및 매뉴얼을 준수하여야 한다.

나. 의료원의 자산에 접근하기 위해서는 의료원의 접근통제 절차를 준수하여야 한다.

다. 의료원은 계약서의 보안사항을 준수하고 있는지를 감사할 권한을 가진다.

라. 의료원의 감사시 필요한 근거 자료를 제공하고 현장실사에 적극 협조하여야 한다.

2. 외부자의 직원에 대한 보안관리

가. 참여직원에 대해서 각 개인의 친필서명이 들어간 정보보호서약서를 제출한다.

나. 참여직원은 임의로 교체할 수 없으며, 교체시 의료원의 승인을 받는다.

3. 자료에 대한 보안관리

가. 업무수행을 위해 제공하는 내부자료는 열람□제공 자료관리대장을 작성하여 인수□인계시 직접 서명한다.

나. 제공된 내부자료에 대해 복사 및 외부반출을 할 수 없으며, 업무완료후 의료원에 반환한다.

다. 제공된 내부자료는 매일 퇴근시 반납하여야 한다. 다만, 비밀문서를 제외한 일반문서는 외부자에 제공된 사무실에 시건장치가 된 보관함이 있을 경우 이를 보관함에 보관할 수 있다.

라. 의료원은 외부자에 제공된 사무실에 보관된 자료에 대해서는 수시로 확인할 수 있다.

4. 장비에 대한 보안관리

가. PC(노트북 포함)는 반입시마다 최신 바이러스 백신프로그램 설치와 바이러스 감염 여부를 확인하여야 한다.

나. 업무수행을 위해 반입된 PC는 업무종료시까지 반출을 할 수 없다. 다만, 불가피한 경우 의료원의 승인 후 반출할 수 있다.

다. USB 등의 보조기억매체는 사용할 수 없다. 다만, 불가피한 경우는 의료원의 승인 후 사용할 수 있다.

라. 업무종료시 PC 및 사용된 보조기억매체는 완전삭제하고 의료원의 승인 후 반출한다.

5. 내. 외부망 접근에 대한 보안관리

가. 사용자 계정은 하나의 그룹으로 등록하고 사용자 계정별로 정보시스템에 접근권한을 부여토록 한다.

나. 사용자 계정별로 부여된 권한은 불필요 시 곧바로 권한을 해지하거나 계정을 폐기토록 한다.

다. 의료원은 사용자별로 부여한 계정에 접속하여 저장된 자료와 작업이력을 확인할 수 있다.

라. 담당자는 시스템관리자로 하여금 내부 서버에 대한 접근기록을 확인하도록 한다.

마. PC(노트북 포함)는 인터넷 연결을 금지한다. 다만, 불가피한 경우는 필요한 보안조치를 실시하고 의료원의 확인 후 사용한다.

6. 기타 산출물에 대한 보안관리 등

가. 업무수행시 생산되는 모든 산출물은 담당 부서의 파일서버에 저장하거나, 의료원에서 지정한 PC에 저장한다.

나. 업무수행으로 생산되는 모든 산출물 및 기록은 의료원이 인가하지 않은 자에게 제공○대여○열람을 금지한다.

다. 업무수행으로 생산되는 모든 산출물 및 기록의 소유권 및 지적재산권은 의료원에 있다.

라. 제3자에 의한 보안사고 발생시 민□형사상의 모든 법적 책임은 제3자에게 있다.

마. 보안사고 발생 시 또는 인지시에는 즉시 의료원에 통보하여야 한다.

[별지 제3호 서식] 정보화 용역사업 시 계약서

개인정보처리위탁 계약서

연세대학교 의료원(이하 “위탁자”이라 한다)과 계약대상자(이하 “수탁자”이라 한다)는 “위탁자”의 개인정보 처리업무를 “수탁자”에게 위탁함에 있어 다음과 같은 내용으로 본 업무 위탁계약을 체결한다.

제1조 (목적) 이 계약은 “위탁자”가 개인정보처리업무를 “수탁자”에게 위탁하고, “수탁자”는 이를 승낙하여 “수탁자”의 책임아래 성실하게 업무를 완성하도록 하는데 필요한 사항을 정함을 목적으로 한다.

제2조 (용어의 정의) 본 계약에서 별도로 정의되지 아니한 용어는「개인정보 보호법」, 같은 법 시행령 및 시행규칙,「개인정보의 안전성 확보조치 기준」(개인정보보호위원회 고시 제2020-2호) 및「표준 개인정보 보호지침」(개인정보보호위원회 고시 제2020-1호)에서 정의된 바에 따른다.

제3조 (위탁업무의 목적 및 범위) “수탁자”는 계약이 정하는 바에 따라 ”본 계약“에 명시된 업무의 목적 및 범위로 개인정보 처리 업무를 수행한다.

제4조 (위탁업무 기간) 이 계약서에 의한 개인정보 처리업무의 기간은 ”본 계약“ 기간에 따른다.

제5조 (재위탁 제한) ① “수탁자”는 “위탁자”의 사전 승낙을 얻은 경우를 제외하고 “위탁자”와의 계약상의 권리와 의무의 전부 또는 일부를 제3자에게 양도하거나 재위탁할 수 없다.

② “수탁자”가 다른 제3의 회사와 수탁계약을 할 경우에는 “수탁자”는 해당 사실을 계약 체결 7일 이전에 “위탁자”에게 통보하고 협의하여야 한다.

제6조 (개인정보의 안전성 확보조치) “수탁자”는「개인정보 보호법」제23조제2항 및 제24조제3항 및 제29조, 같은 법 시행령 제21조 및 제30조, 「개인정보의 안전성 확보조치 기준」(개인정보보호위원회 고시 제2020-2호)에 따라 개인정보의 안전성 확보에 필요한 관리적. 기술적 조치를 취하여야 한다.

제7조 (개인정보의 처리제한) ① “수탁자”는 계약기간은 물론 계약 종료 후에도 위탁업무 수행 목적 범위를 넘어 개인정보를 이용하거나 이를 제3자에게 제공 또는 누설하여서는 안 된다.

② “수탁자”는 계약이 해지되거나 또는 계약기간이 만료된 경우 위탁업무와 관련하여 보유하고 있는 개인정보를 「개인정보 보호법」시행령 제16조 및「개인정보의 안전성 확보조치 기준」(개인정보보호위원회 고시 제2020-2호)에 따라 즉시 파기하거나 “위탁자”에게 반납하여야 한다.

③ 제2항에 따라 “수탁자”가 개인정보를 파기한 경우 지체없이 “위탁자”에게 그 결과를 통보하여야 한다.

제8조 (수탁자에 대한 관리·감독 등) ① “위탁자”는 “수탁자”에 대하여 다음 각 호의 사항을 감독할 수 있으며, “수탁자”는 특별한 사유가 없는 한 이에 응하여야 한다.

1. 개인정보의 처리 현황
2. 개인정보의 접근 또는 접속현황
3. 개인정보 접근 또는 접속 대상자

4. 목적외 이용. 제공 및 재위탁 금지 준수여부
5. 암호화 등 안전성 확보조치 이행여부
6. 그 밖에 개인정보의 보호를 위하여 필요한 사항

② “위탁자”는 “수탁자”에 대하여 제1항 각 호의 사항에 대한 실태를 점검하여 시정을 요구할 수 있으며, “수탁자”는 특별한 사유가 없는 한 이행하여야 한다.

③ “위탁자”는 처리위탁으로 인하여 정보주체의 개인정보가 분실·도난·유출·변조 또는 훼손되지 아니하도록 1년에 1회 “수탁자”를 교육 또는 교육 이력을 요청할 수 있으며, “수탁자”는 이에 응하여야 한다.

④ 제1항에 따른 교육의 시기와 방법 등에 대해서는 “위탁자”는 “수탁자”와 협의하여 시행한다.

제9조 (정보주체 권리보장) ① “수탁자”는 정보주체의 개인정보 열람, 정정·삭제, 처리정지 요청 등에 대응하기 위한 연락처 등 민원 창구를 마련해야 한다.

제10조 (개인정보의 파기) ① “수탁자”는 제4조의 위탁업무기간이 종료되면 특별한 사유가 없는 한 지체 없이 개인정보를 파기하고 이를 “위탁자”에게 확인받아야 한다.

제11조 (손해배상) ① “수탁자” 또는 “수탁자”의 임직원 기타 “수탁자”의 수탁자가 이 계약에 의하여 위탁 또는 재위탁 받은 업무를 수행함에 있어 이 계약에 따른 의무를 위반하거나 “수탁자” 또는 “수탁자”의 임직원 기타 “수탁자”의 수탁자의 귀책사유로 인하여 이 계약이 해지되어 “위탁자” 또는 개인정보주체 기타 제3자에게 손해가 발생한 경우 “수탁자”는 그 손해를 배상하여야 한다.

② 제1항과 관련하여 개인정보주체 기타 제3자에게 발생한 손해에 대하여 “위탁자”가 전부 또는 일부를 배상한 때에는 “위탁자”는 이를 “수탁자”에게 구상할 수 있다.

본 계약의 내용을 증명하기 위하여 계약서 2부를 작성하고, “위탁자”와 “수탁자”가 서명 또는 날인한 후 각 1부씩 보관한다.

※ 개인정보처리 위탁 업무에 해당하지 않는 경우 본 계약서의 내용은 적용하지 않음

20 . . .

위탁자	수탁자
주 소 :	주 소 :
기관(회사)명 :	기관(회사)명 :
대표자 성명 : (인)	대표자 성명 : (인)